Mac Remote Workspace

Tài liệu thiết kế ứng dụng macOS-first · Version 1.0

Software Design Specification

26/10/2026

Phạm vi và cách đọc

Mac Remote Workspace — phần mềm Open Source, macOS-first, local-first, hỗ trợ quản lý SSH, SFTP và RDP.
Công nghệ đề xuất: React 19, TypeScript, Tauri 2, Rust, SQLite, Keychain.
P0: SSH, SFTP, workspace, vault. **P1:** RDP qua client ngoài, SSH tunnel. **P2:** RDP nhúng nếu qua đánh giá kỹ thuật.
Tài liệu: thiết kế triển khai, chưa phải phần mềm đã hoàn thiện; KPI và khả năng tương thích phải kiểm thử trước khi công bố.

Mục lục

D01 — Product Requirements Document (PRD)

D02 — Software Requirements Specification (SRS)

D03 — User Journey, Flows & State Design

D04 — UX/UI Design System & Wireframes

D05 — Solution Architecture (C4 + Runtime)

D06 — Domain Model, ERD & SQLite Schema

D07 — SSH, SFTP, RDP, Tunnels & Session Lifecycle

D08 — Tauri IPC Commands, Events and Domain Contracts

D09 — Security Architecture & Threat Model

D10 — Test Strategy, Test Matrix and Quality Gates

D11 — Build, Release, Distribution & Operational Runbook

D12 — Roadmap, Epics, User Stories & Work Breakdown

D13 — Architecture Decision Records, Risks and Spikes

D14 — Open Source Governance, License and Community Plan

D15 — Research and Technical References

D16 — Implementation Blueprint and Repository Layout

D01 — Product Requirements Document (PRD)

1. Vấn đề và cơ hội

Developer/IT support phải quản lý cùng lúc máy Linux và Windows của nhiều khách hàng. Họ chuyển qua lại giữa Terminal, ứng dụng RDP, FileZilla/Cyberduck, spreadsheet chứa địa chỉ máy chủ và ghi chú. Việc chuyển ngữ cảnh gây mất thời gian và có nguy cơ nhập lệnh/đẩy file nhầm vào production. Nhiều sản phẩm cạnh tranh đã bao quát SSH, RDP, SFTP (ví dụ Termix); cơ hội không phải “all-in-one đầu tiên”, mà là **workspace macOS-native, local-first, ưu tiên độ rõ ràng của ngữ cảnh và an toàn khi vận hành**.

2. Product statement

Mac Remote Workspace (MRW) giúp một kỹ thuật viên mở đúng máy chủ, đúng môi trường và đúng giao thức từ một cửa sổ, đồng thời quản lý kết nối, thông tin đăng nhập, phiên làm việc và truyền file theo cách có thể kiểm tra, có thể giải thích, có kiểm soát.

Giá trị khác biệt cần kiểm chứng

Context-first: máy chủ được nhóm theo khách hàng/dự án/môi trường và hiển thị cảnh báo PROD cố định.

Native credential safety: bí mật không cần cloud account; tích hợp Keychain, SSH Agent.

Workflow continuity: terminal và SFTP có thể dùng chung host profile, mỗi session có lịch sử trạng thái nhưng không ghi nội dung terminal theo mặc định.

Reliable transport: kết nối bị gián đoạn thông báo rõ nguyên nhân, không âm thầm chạy lại lệnh có thể gây tác động.

Cross-platform growth: core adapters có thể tái sử dụng nhưng thiết kế UX ưu tiên macOS trước.

3. Personas

P-A Developer fullstack — **Bối cảnh:** 5–20 server, Linux/.NET/React; **Jobs-to-be-done:** SSH debug, SFTP upload, kiểm tra log; **Pain point:** Chuyển app, nhầm host; **Ưu tiên:** P0

P-B IT Support — **Bối cảnh:** 10–100 host/khách hàng; **Jobs-to-be-done:** Mở Windows RDP, hỗ trợ người dùng; **Pain point:** Danh bạ rời rạc, credentials khó tìm; **Ưu tiên:** P1

P-C SysAdmin — **Bối cảnh:** Nhiều environment; **Jobs-to-be-done:** SSH tunnel, server file inspect; **Pain point:** Cấu hình nguy hiểm khi thiếu context; **Ưu tiên:** P0/P1

P-D Agency/Consultant — **Bối cảnh:** Nhiều khách hàng; **Jobs-to-be-done:** Nhóm workspace, chuyển công việc nhanh; **Pain point:** Dễ thao tác trên tenant sai; **Ưu tiên:** P0

4. Top user outcomes

Người dùng thêm host Linux và kết nối SSH có xác minh identity trong dưới 2 phút ở happy path (target UX, không phải benchmark).

Mở terminal và SFTP của cùng host từ một profile, không nhập lại endpoint.

Nhìn thấy rõ môi trường PROD/STAGING/DEV trước mọi thao tác ghi file.

Mở RDP của Windows host qua client ngoài, không lộ password ở command-line.

Chuyển nhóm khách hàng/workspace, giữ session đang chạy khi đổi tab nếu hệ thống còn khả dụng.

5. In-scope / out-of-scope

P0 MVP — **In scope:** host CRUD; groups/tags; secrets references; SSH terminal; SFTP browser/upload/download; session state; keyboard shortcuts; import/export public metadata; audit metadata; **Ngoài phạm vi:** RDP embedded; cloud sync; multiuser; auto script execution; VNC/Telnet; AI agents

P1 1.0 — **In scope:** RDP launcher (external), SSH local port forwarding, profiles search, diagnostics; configurable snippets với confirmation; **Ngoài phạm vi:** Remote port forwarding mặc định; team credentials; recorded terminal

P2 2.0 — **In scope:** Embedded RDP feasibility+shipping, multi-monitor, SSH jump hosts (nếu spike), stats, plugin APIs; **Ngoài phạm vi:** Full-blown PaaS; password sharing cloud

6. Success measures — đề xuất sau 60 ngày beta

Activation: >=60% testers thêm được một host và mở SSH thành công (trên môi trường có network access).

Task completion: >=90% người thử chuyển từ Host List sang terminal/SFTP không cần hỗ trợ.

Stability: >=99% app sessions kết thúc không crash trên tập máy beta được theo dõi opt-in hoặc thông qua bug reports.

Security: 0 secrets trong logs/SQLite/export; 100% mismatch host key bị chặn trong integration tests.

UX: 90th-percentile mở host profile từ launcher dưới 2 giây trên máy thử định nghĩa; SSH handshake phụ thuộc mạng đo riêng.

Maintainability: >=80% unit test cho core state machine/validation, không dùng chỉ số này để thay thế end-to-end.

Lưu ý: KPI là mục tiêu. Cỡ mẫu beta, thiết bị, loại mạng và cách đo cần đăng ký trước khi công bố.

7. Competitor baseline

Termix: quản lý SSH, RDP, VNC, SFTP, Docker, tunnel và desktop standalone; đây là baseline cạnh tranh, không phải "khoảng trống chưa ai làm".

1Remote: thiên về Windows, hỗ trợ nhiều protocol và launcher.

FreeRDP: thư viện/protocol engine chứ không phải thiết kế UX.

Ứng dụng chuyên SSH/SFTP: lợi thế ở độ sâu từng giao thức; MRW không nên cố sao chép đầy đủ ngay.

8. Monetization và open-source

Mặc định phần desktop core miễn phí, không yêu cầu tài khoản. Nếu về sau có dịch vụ có phí, chỉ nên là tính năng tùy chọn ngoài core (ví dụ quản lý nhóm với E2EE được thiết kế riêng), và phải công khai mô hình giấy phép. Không được tuyên bố "free forever" nếu chưa có quyết định quản trị dự án.

9. Launch narrative

Early testers: developer dùng macOS + Linux VPS; nhỏ gọn, kiểm thử SSH/SFTP và Keychain trước.

Public beta: thêm RDP external launcher, signed+notarized artifact, tài liệu khắc phục lỗi.

Post-launch: tập trung reliability, khảo sát RDP nhúng thay vì cam kết ngày ra mắt.

10. Rủi ro định vị

Quá nhiều tính năng tạo bản clone kém chất lượng; cần ưu tiên workflow có thể đo.

"Native" có thể bị hiểu là 100% SwiftUI; định nghĩa chính xác: **native desktop packaging/integration trên macOS**, UI được render bởi system WebView qua Tauri.

Apple notarization/code signing và sandbox có thể ảnh hưởng hỗ trợ file access/sidecar; phải kiểm thử sớm.

D02 — Software Requirements Specification (SRS)

1. Quy ước

MUST = P0, SHOULD = P1, COULD = P2. Tất cả test IDs được đối chiếu trong checklists/requirements-traceability.csv. Nhóm module: HOST (H), AUTH (A), SSH (S), SFTP (F), SESSION (E), RDP (R), DATA (D), UX (U), NETWORK (N).

2. Functional requirements

FR-001 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Tạo host với tên, address, port, protocol, environment, credential reference; **Acceptance criteria (định lượng/xác định):** Validate port 1–65535, hostname, required fields; không cho host trống

FR-002 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** CRUD host/group/tag với delete confirmation; **Acceptance criteria (định lượng/xác định):** Xóa host xóa liên kết metadata, không tự xóa secrets được dùng bởi host khác

FR-003 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Search/filter host theo tên, tag, env, protocol; **Acceptance criteria (định lượng/xác định):** Search không phân biệt chữ hoa thường; debounce; không truy vấn secrets

FR-004 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Vault lưu và tham chiếu password/passphrase trong Keychain; **Acceptance criteria (định lượng/xác định):** SQLite chỉ lưu UUID credential_ref, không chứa giá trị secret

FR-005 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** SSH auth password, key file, ssh-agent; **Acceptance criteria (định lượng/xác định):** Lỗi auth được phân biệt với network/host-key lỗi

FR-006 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** SSH host key verification trước auth; **Acceptance criteria (định lượng/xác định):** Unknown => fingerprint+approval; mismatch => block, không auto trust

FR-007 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Terminal tab, resize PTY, copy/paste, UTF-8; **Acceptance criteria (định lượng/xác định):** Resize truyền SSH window change; >=2 tabs cùng lúc

FR-008 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** SSH connect/disconnect/retry có state rõ; **Acceptance criteria (định lượng/xác định):** Retry chỉ tái kết nối session; không chạy lại command đã gửi

FR-009 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** SFTP duyệt cây, breadcrumb, file metadata; **Acceptance criteria (định lượng/xác định):** Có xử lý thư mục rỗng, quyền truy cập, symbolic link

FR-010 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** SFTP upload/download với queue, cancel và status; **Acceptance criteria (định lượng/xác định):** File partial không hiển thị như đã hoàn tất; cancel không phá file đích mặc định

FR-011 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Delete/overwrite/rename trên SFTP với confirm có target path; **Acceptance criteria (định lượng/xác định):** Production có cảnh báo nâng cao; không cho xóa ngoài lựa chọn

FR-012 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Workspace nhóm host, khôi phục layout/tab metadata; **Acceptance criteria (định lượng/xác định):** App restart không tự login lại khi chưa consent hoặc secrets locked

FR-013 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Audit event metadata local, redacted; **Acceptance criteria (định lượng/xác định):** Ghi outcome/error code, không ghi terminal IO hay file contents

FR-014 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Export/import cấu hình không secrets theo versioned schema; **Acceptance criteria (định lượng/xác định):** Export loại password, private key bytes, fingerprint ngoại lệ; import dry-run và xử lý trùng

FR-015 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Giao diện keyboard-first, light/dark, accessibility; **Acceptance criteria (định lượng/xác định):** Focus visible, VoiceOver labels, shortcut collision tests

FR-016 — **Ưu tiên:** SHOULD; **Yêu cầu cụ thể:** Mở RDP từ host profile bằng external client; **Acceptance criteria (định lượng/xác định):** Không đặt password trong process arguments/URL; hướng dẫn login trong client

FR-017 — **Ưu tiên:** SHOULD; **Yêu cầu cụ thể:** SSH local port forwarding có quản lý lifecycle; **Acceptance criteria (định lượng/xác định):** Binding local mặc định 127.0.0.1; đóng session thì close tunnel

FR-018 — **Ưu tiên:** SHOULD; **Yêu cầu cụ thể:** Connection diagnostics: DNS, TCP, SSH handshake timing; **Acceptance criteria (định lượng/xác định):** Kết quả cho biết lớp lỗi; không lưu endpoint credentials vào report

FR-019 — **Ưu tiên:** SHOULD; **Yêu cầu cụ thể:** Snippet theo host/group, chỉ chạy sau user confirmation; **Acceptance criteria (định lượng/xác định):** Preview text/target, cấm auto-execute lúc connect

FR-020 — **Ưu tiên:** SHOULD; **Yêu cầu cụ thể:** Quick switch workspace/command palette; **Acceptance criteria (định lượng/xác định):** Cmd+K hoặc shortcut đã kiểm tra xung đột

FR-021 — **Ưu tiên:** COULD; **Yêu cầu cụ thể:** RDP embedded view qua FreeRDP native adapter; **Acceptance criteria (định lượng/xác định):** NLA/TLS, keyboard/clipboard/HiDPI kiểm thử theo matrix trước GA

FR-022 — **Ưu tiên:** COULD; **Yêu cầu cụ thể:** SSH jump host / ProxyJump; **Acceptance criteria (định lượng/xác định):** Chain host key validation riêng, không lộ secret downstream

FR-023 — **Ưu tiên:** COULD; **Yêu cầu cụ thể:** Dashboard server metrics qua safe readonly commands; **Acceptance criteria (định lượng/xác định):** Có opt-in; xác định distro compatibility

FR-024 — **Ưu tiên:** COULD; **Yêu cầu cụ thể:** Plugin API cho protocol adapters; **Acceptance criteria (định lượng/xác định):** Signed manifest/capability model; không chạy untrusted native code ngầm

FR-025 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Credential unlink và orphan cleanup có confirmation; **Acceptance criteria (định lượng/xác định):** Xóa host không xóa shared credential đang dùng; hiện ảnh hưởng trước action

FR-026 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** External link/file path open có kiểm tra; **Acceptance criteria (định lượng/xác định):** URL schemes allowlist, không shell interpolate input người dùng

FR-027 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Reconnect storm prevention; **Acceptance criteria (định lượng/xác định):** Exponential backoff, jitter, cap, user cancel; không retry credentials invalid vô hạn

FR-028 — **Ưu tiên:** MUST; **Yêu cầu cụ thể:** Session close và app quit xử lý active transfer; **Acceptance criteria (định lượng/xác định):** Nhắc cancel/finish; teardown socket/subprocess không để child sống sót

3. Business rules

BR-01: Host name có thể trùng; host_id UUID là định danh duy nhất. Duplicates có warning dựa trên endpoint nhưng không cấm tuyệt đối (nhiều account).

BR-02: environment=production làm thay đổi giao diện cảnh báo và confirmation, không thay quyền truy cập OS.

BR-03: Một credential có thể gắn cho nhiều host qua reference; xóa credential phải hiển thị danh sách liên quan.

BR-04: Session ngắn hạn; đóng app thì in-memory secrets/SSH handles phải bị hủy; chỉ persistence metadata của tab/layout.

BR-05: RDP external launcher không hứa embed, clipboard isolation hoặc seamless credential handoff.

BR-06: Symlink SFTP có thể trỏ ra ngoài folder; mọi thao tác destructive phải hiện canonical/remote path nếu có thể giải được, và thực hiện trên đối tượng người dùng chọn.

BR-07: Không lưu terminal transcript mặc định, không gửi telemetry mặc định; crash report chỉ opt-in.

BR-08: Import không mặc định ghi đè known_hosts; trust decisions phải xác nhận tại máy mới.

4. Nonfunctional requirements

NFR-001 Performance — **Mục tiêu thiết kế và phương pháp đo:** Cold start target p90 <= 3s trên Mac Apple Silicon tiêu chuẩn định nghĩa sau; đo 30 lần, tách startup app và network

NFR-002 Responsiveness — **Mục tiêu thiết kế và phương pháp đo:** Input terminal render mục tiêu không lag dễ nhận thấy với 10 SSH sessions; đo trên LAN/WAN giả lập và payload throughput giới hạn

NFR-003 Stability — **Mục tiêu thiết kế và phương pháp đo:** 8h soak 10 sessions + transfer queue, không memory leak xu hướng tăng vô hạn, không orphan subprocess

NFR-004 Security — **Mục tiêu thiết kế và phương pháp đo:** Không có secrets trong SQLite, logs, exports, crash reports; fuzz validation host/path/events; signed+notarized release

NFR-005 Recoverability — **Mục tiêu thiết kế và phương pháp đo:** Transfer interruption được đánh dấu FAILED/CANCELLED; retry có explicit action; không ghi đè đích khi chưa complete

NFR-006 Offline — **Mục tiêu thiết kế và phương pháp đo:** Host inventory/workspace sử dụng được không mạng; connect fail giải thích rõ

NFR-007 Accessibility — **Mục tiêu thiết kế và phương pháp đo:** WCAG 2.2 AA làm mục tiêu UX; keyboard-only, VoiceOver và reduced motion phải kiểm thử thực tế

NFR-008 Compatibility — **Mục tiêu thiết kế và phương pháp đo:** Baseline target macOS 13+, arm64/x86_64; Xcode/macOS CI matrix có smoke tests; điều chỉnh sau spike

NFR-009 Observability — **Mục tiêu thiết kế và phương pháp đo:** Structured redacted local logs, log retention 7d mặc định, max size/cap theo cấu hình

NFR-010 Data integrity — **Mục tiêu thiết kế và phương pháp đo:** Migrations transactional, rollback khi lỗi; backup metadata trước schema upgrade

NFR-011 Packaging — **Mục tiêu thiết kế và phương pháp đo:** Developer ID signing, hardened runtime, notarization/stapling; SBOM và dependency review

NFR-012 Privacy — **Mục tiêu thiết kế và phương pháp đo:** No-account/no-tracking mặc định; update check tùy chọn, công bố network calls

NFR-013 Scalability — **Mục tiêu thiết kế và phương pháp đo:** Inventory 1,000 hosts vẫn search/filter không lag đáng kể; thử dataset fixture với 10k

NFR-014 Maintainability — **Mục tiêu thiết kế và phương pháp đo:** Core service tách theo domain; protocol engine sau interface; required ADR cho đổi phụ thuộc lớn

5. Constraints / compatibility

Apple sandbox/security scoped bookmarks cần kiểm tra nếu chọn phân phối qua Mac App Store; kế hoạch đầu tiên Developer ID notarized direct download.

SSH2 crate dùng libssh2/SSL trên macOS: cần kiểm tra signing và binary dependency.

FreeRDP native embed chưa được xác thực với Tauri WebView; P2 được coi là **spike-gated**.

Host trust phải theo hostname+port và key fingerprint, không đơn thuần dựa trên địa chỉ IP.

6. Requirement change control

Mỗi thay đổi requirement phải cập nhật mã FR, ưu tiên, acceptance tests, UX và ADR liên quan. Không thể đóng issue nếu acceptance criteria chưa có bằng chứng test/screenshot/log redacted.

D03 — User Journey, Flows & State Design

1. UJ-01: First-run onboarding

Actor: developer lần đầu dùng ứng dụng. **Goal:** tạo SSH connection thành công và hiểu security defaults.

Welcome giải thích local-first, no account, secrets dùng Keychain, không tự chạy remote commands.

Prompt tạo workspace (ví dụ Production / Customer A) hoặc dùng Personal.

Add Host: display name, FQDN/IP, port=22, username, auth method, environment.

Nếu password: lưu vào Keychain sau sự đồng ý. Nếu key: chọn key path bằng file picker; ưu tiên SSH agent nếu sẵn.

Connect: thực hiện TCP, SSH negotiation, **host key verification**, rồi mới authentication.

Unknown host key: hiển thị algorithm, SHA256 fingerprint, hostname:port, hướng dẫn xác minh bằng kênh độc lập; Cancel hoặc Trust once/Trust and save.

Sau auth thành công: mở terminal; SFTP có thể mở trên tab kế bên với cùng profile.

Errors: timeout, host-key mismatch, auth denied, bad private-key passphrase, unsupported key, permission denied. Mỗi lỗi có remediation rõ; mismatch tuyệt đối không có nút Connect anyway tự động bỏ qua xác minh.

```
flowchart TD
 A[Create workspace] --> B[Add SSH host]
 B --> C[Validate fields]
 C --> D[TCP and SSH handshake]
 D --> E{Host identity known?}
 E -->|Matched| G[Authenticate]
 E -->|Unknown| F[Show SHA256 fingerprint & confirm]
 E -->|Mismatch| X[Block and investigate]
 F -->|Approved| G
 F -->|Cancelled| Z[Disconnect]
```

```
G -->|Success| H[Open terminal]
G -->|Failure| I[Show auth error; manual retry]
```

2. UJ-02: Production SSH & SFTP

User vào customer workspace, chọn host có badge PROD.

Mở terminal; app hiển thị username@host + endpoint + identity status trong tab.

User chọn Open SFTP → server path hiện rõ ở breadcrumb, local path ở pane bên trái.

User upload file, app kiểm tra tên/size, phát hiện conflict, đưa ra lựa chọn Skip/Rename/Overwrite.

Upload vào temporary remote target (nếu quyền và SFTP hỗ trợ), verify size/integrity theo capability và rename atomic nếu cùng filesystem; fallback được cảnh báo.

Khi cancel, xóa temp do app tạo nếu an toàn; không xóa file đích tồn tại từ trước.

Event metadata được ghi: operation, host_id, start/finish/outcome, **không ghi nội dung file**.

3. UJ-03: Reconnect from network loss

State CONNECTED → INTERRUPTED; terminal hiển thị banner, input bị disable; app cho Retry/Close. Retry tạo **session mới**, không replay shell input/paste hay lệnh đã gửi. Nếu network flap, retry throttled với user cancellation. SFTP transfer đang chạy chuyển FAILED/INTERRUPTED và cần explicit retry. Tránh tự động hoàn tất upload trùng file.

4. UJ-04: Windows RDP (P1)

User chọn host protocol=RDP → Open in RDP Client; nếu client chưa có, app hướng dẫn cài đặt và hiển thị profile details có thể sao chép. Launcher phải dùng API mở tài liệu/profile không chứa mật khẩu, hoặc sinh file cấu hình tạm có permissions chặt và cleanup. Nếu không thể tích hợp an toàn/khả dụng, fallback là copy host:port và hướng dẫn mở client. Không claim clipboard/credential sharing với client ngoài.

5. UJ-05: Import/export host list

Export metadata-only.json có schema_version, host/group/tags, non-secret connection settings. Credential ref trong export được thay bằng auth_required=true, không đi theo máy.

Import preview: tổng host, duplicate (endpoint/user/protocol), invalid entries, group mapping. Chọn Skip / Merge metadata / Create copy trước apply transaction.

Imported trusted host keys phải được xác minh lại hoặc nhập qua phương thức nâng cao được kiểm soát; không auto-trust fingerprints trong file không xác thực.

6. UJ-06: Session close with pending transfer

User đóng tab SFTP khi 2 transfer đang chạy. Dialog hiển thị Keep transfer running (nếu app còn chạy) / Cancel transfers / Back. Khi quit app, chỉ Cancel + exit hoặc Back cho MVP; tính năng tiếp tục chạy background sau quit chưa hỗ trợ. Transfers phải chuyển state và persist metadata trước khi thoát.

7. User-facing states

Host list — **States bắt buộc:** Empty, Loading, Loaded, Error; **Thông điệp:** First host CTA, search zero results, DB read failure

SSH — **States bắt buộc:** Idle, Resolving, Connecting, Verifying, Authenticating, Connected, Interrupted, Closing, Closed, Failed; **Thông điệp:** Tên lỗi tách rõ DNS/TCP/trust/auth

SFTP — **States bắt buộc:** Browsing, Transferring, Paused (nếu hỗ trợ), Cancelled, Failed, Completed; **Thông điệp:** Số bytes thực chuyển, tốc độ, đường dẫn đích

RDP external — **States bắt buộc:** Client missing, Launching, Launched, Failed; **Thông điệp:** Không hiển thị "Connected" vì app không kiểm soát phiên ngoài

Vault — **States bắt buộc:** Available, Locked/Prompt, Denied, Not found; **Thông điệp:** Không spam prompt password hoặc auto unlock

8. Keyboard shortcuts (đề xuất)

Cmd+K: command palette; Cmd+N: new host; Cmd+T: new terminal tab; Cmd+W: close active tab (cảnh báo transfer); Cmd+Shift+F: file search; Cmd+1/2/3: switch panels (kiểm tra va chạm với terminal). Toàn bộ shortcut có thể override nếu xung đột với xterm/OS, và được test với layout bàn phím khác nhau.

9. Error taxonomy

DNS_RESOLUTION_FAILED, TCP_TIMEOUT, TCP_REFUSED, HOST_KEY_UNKNOWN, HOST_KEY_MISMATCH, SSH_NEGOTIATION_FAILED, AUTH_FAILED, CREDENTIAL_UNAVAILABLE, SFTP_PERMISSION_DENIED, TRANSFER_INTERRUPTED, TRANSFER_CONFLICT, RDP_CLIENT_MISSING, LOCAL_PERMISSION_DENIED, UNEXPECTED_INTERNAL.

Không hiển thị stack trace cho end-user. Details cung cấp event id, code, endpoint redacted và suggested next step.

D04 — UX/UI Design System & Wireframes

1. UX principles

Context always visible: breadcrumb nhóm/host/environment, PROD caution trên mọi terminal/SFTP tab.

One primary action: New host, Connect, Open SFTP không bị nhấn chìm trong settings.

No ambiguous trust: host fingerprint và certificate warning không dùng màu "success" hoặc auto-accept.

Keyboard-first: command palette, navigation tab, accessible focus, shortcut discoverability.

Progress is truthful: trạng thái "Connecting" ≠ "Connected"; transfer progress dựa trên bytes confirmed.

Reversible by design: ghi đè/xóa cần xác nhận mục tiêu rõ, không nút destructive đặt sát nút primary.

2. Information architecture

Application
├── Home
│ ├── Recents / Favorites
│ ├── Workspace picker
│ └── Search / Command palette
├── Workspaces
│ ├── Groups / Hosts
│ └── Tabs
│ ├── SSH Terminal
│ ├── SFTP File Manager
│ └── RDP External Launcher (P1)
├── Transfers
│ ├── In progress
│ └── Completed/Failed
├── Credentials
│ └── Credential references (never reveal raw secret by default)
├── Known Hosts
│ └── Fingerprint details / review changes
└── Settings

```
├── Appearance & Accessibility
├── SSH/SFTP Defaults
├── Privacy & Diagnostics
└── About, Licenses, Updates
```

3. Desktop shell wireframe (1440×900 reference)

```
┌──────────────────────────────────────────────────────────────────────────────┐
│ MRW   [Production / Client A ▼]        Search hosts   ⚙   ▯                  │
├──────────────────┬──────────────────────────────────────────────────────────┤
│ Workspaces       │ SSH: ubuntu-prod ●     SFTP: ubuntu-prod                 │
│ ▾ Client A       ├──────────────────────────────────────────────────────────┤
│   ● Ubuntu A     │ [PRODUCTION] ubuntu@ubuntu-a.example:22   ● Trusted       │
│   ● Ubuntu B     │                                                          │
│   ◇ Windows DB   │ $ systemctl status nginx                                 │
│ ▸ Client B       │ ● active (running)                                       │
│                  │ $ _                                                      │
│ Favorites        │                                                          │
│ Recents          │                                                          │
├──────────────────┤                                                          │
│ [+ Add host]     │                                                          │
├──────────────────┴──────────────────────────────────────────────────────────┤
│ Transfers: 1 pending      SSH encrypted · Last network check: 20:21         │
└──────────────────────────────────────────────────────────────────────────────┘
```

4. SFTP dual-pane wireframe

```
┌──────────────────────────── Local ──────────────────┬──────── Remote ────────┐
│ ~/Projects/build/        ↑                          │ /var/www/site/     ↑   │
│ Name              Size  Modified                    │ Name          Size     │
│ index.html        2KB   Today                       │ index.html    2KB      │
│ assets/           —     Today                       │ assets/       —        │
│ runtime-config.json  0.3KB  Today                   │ runtime-config.json ...│
├─────────────────────────────────────────────────────┴────────────────────────┤
│ Transfer queue: uploading assets/app.js 2.1/4.2 MB        [Cancel]           │
└──────────────────────────────────────────────────────────────────────────────┘
```

5. Design tokens — baseline (không ràng buộc UI library)

bg.base — **Light:** #F7F9FC; **Dark:** #10151D; **Ý nghĩa:** app background

bg.surface — **Light:** #FFFFFF; **Dark:** #18212D; **Ý nghĩa:** panels

text.primary — **Light:** #1D2939; **Dark:** #F2F4F7; **Ý nghĩa:** body

text.secondary — **Light:** #667085; **Dark:** #98A2B3; **Ý nghĩa:** metadata

accent.primary — **Light:** #246BCE; **Dark:** #77ACFF; **Ý nghĩa:** main actions

status.success — **Light:** #067647; **Dark:** #47C58A; **Ý nghĩa:** connected (kèm icon/text)

status.warning — **Light:** #B54708; **Dark:** #F3B25B; **Ý nghĩa:** trust/production warnings

status.danger — **Light:** #B42318; **Dark:** #F97066; **Ý nghĩa:** destructive/errors

radius.md — **Light:** 8px; **Dark:** 8px; **Ý nghĩa:** controls

space.unit — **Light:** 4px; **Dark:** 4px; **Ý nghĩa:** 4/8/12/16/24/32

Typography: system sans (SF Pro hệ thống, fallback), terminal monospace hệ thống; không bundle font thương mại. Default body 13–14px, content min touch/click target 32×32 desktop, không chỉ dựa vào màu để nhận trạng thái.

6. Component inventory

AppShell, WorkspaceSwitcher, HostTree, HostCard, HostEditor, EnvironmentBadge, SessionTabs, SessionHeader.

SshTerminal, TerminalToolbar, ReconnectBanner, SftpDualPane, RemoteBreadcrumb, FileRow, TransferQueue, OverwriteDialog.

CredentialPicker, FingerprintDialog, KnownHostReviewDialog, RdpLaunchPanel, Toast, ErrorDetails, CommandPalette.

7. Responsive and window policy

Minimum usable window target 1100×700 for dual-pane; below that SFTP panes switch to stacked view; sidebar collapsible.

Narrow sizes require no horizontal clipping on dialogs, keyboard shortcuts accessible.

Tauri multi-window: MVP one main window, dialogs as controlled UI overlays. Embedded RDP (P2) requires separate native surface/window lifecycle.

8. Accessibility checklist

Interactive elements have semantic role/label/description; terminal accessible instructions; contrast target WCAG AA.

VoiceOver navigation order: sidebar → tabs → current content → status/transfer tray.

Keyboard interaction: tab cycle, Esc dismiss non-critical dialogs, no focus trap except modal, no shortcut stealing terminal characters.

prefers-reduced-motion, dynamic type zoom, clear icon+text statuses, announcements on connection state changes.

9. UX acceptance examples

UXT-01: User recognizes active environment before transferring file.

UXT-02: Unknown host key shown with actionable fingerprint comparison, reject path is obvious.

UXT-03: Keyboard-only user can create profile, connect, open SFTP and disconnect.

UXT-04: Failed transfer shows destination path, reason, and safe retry action.

UXT-05: Cancel dialog preserves previous host edit values.

D05 — Solution Architecture (C4 + Runtime)

1. Architecture decision summary

Kiến trúc đề xuất: Desktop modular monolith, local-first; Tauri 2 WebView cho UI, Rust backend cho I/O và policy enforcement. SQLite chỉ lưu metadata. Keychain lưu small secrets. Không yêu cầu backend cloud hoặc agent chạy trên server đích.

```
flowchart LR
 U[Mac User] --> UI[React 19 + TypeScript UI]
 UI <-->|Tauri IPC commands/events| CORE[Rust Application Core]
 CORE --> DB[(SQLite: Metadata)]
 CORE --> KV[(macOS Keychain: Secrets)]
 CORE --> SSH[SSH/SFTP Adapter]
 CORE --> RDP[RDP External Launcher P1]
 SSH -->|SSH 22| LINUX[Linux/BSD/SSH Server]
 RDP -->|External OS Client| WINDOWS[Windows RDP Host]
```

2. C4 context

Person: desktop user. **System:** Mac Remote Workspace. **External systems:** SSH servers, SFTP subsystem, RDP servers via external client, macOS Keychain, OS file system, local SSH agent, local clipboard. Cloud accounts/telemetry servers không tồn tại trong MVP.

Trust zones:

UI WebView là untrusted relative to Rust privileged core; IPC validation bắt buộc.

Rust core được phép I/O local, Keychain và remote network theo lệnh người dùng; phải áp dụng least privilege policy nội bộ.

Remote hosts và file names/data là untrusted; terminal output/SFTP paths không được coi là trusted HTML/code.

External RDP client là process ngoài, không thuộc quản lý session chi tiết của MRW.

3. Container/module decomposition

ui-shell — **Responsibility:** Layout, navigation, dialogs, command palette; **Interface:** hooks + feature stores; **Ownership:** Frontend

ui-terminal — **Responsibility:** xterm.js presentation, input/resize mapping; **Interface:** TerminalPort; **Ownership:** Frontend

ui-files — **Responsibility:** local/remote file lists + transfer queue; **Interface:** SftpPort; **Ownership:** Frontend

ipc-contract — **Responsibility:** Types, versioning, validation; **Interface:** typed commands/events; **Ownership:** Shared

app-core — **Responsibility:** Policy, orchestration, session registry; **Interface:** Rust commands; **Ownership:** Rust

host-repository — **Responsibility:** Metadata CRUD & migration; **Interface:** SQLite; **Ownership:** Rust

secret-store — **Responsibility:** Keychain refs, unlock/delete; **Interface:** SecretStore trait; **Ownership:** Rust

ssh-transport — **Responsibility:** handshake, verify, auth, shell channels; **Interface:** SshTransport trait; **Ownership:** Rust

sftp-service — **Responsibility:** operations, transfer workers; **Interface:** FileTransfer trait; **Ownership:** Rust

rdp-launcher — **Responsibility:** external RDP client integration; **Interface:** RdpLauncher trait; **Ownership:** Rust (P1)

event-hub — **Responsibility:** bounded event queue, stream lifecycle; **Interface:** Tauri events; **Ownership:** Rust

audit-log — **Responsibility:** redacted metadata and diagnostics; **Interface:** SQLite/log file; **Ownership:** Rust

4. Core design: interfaces, dependency inversion

```
UI (features) -> typed invoke layer -> app-core policy
                    -> HostRepository/SessionRegistry
                    -> SSHTransport, SFTPService, SecretStore, RdpLauncher
```

Core không phụ thuộc React component. UI không thao tác file/Keychain/SSH trực tiếp. Tách protocol adapters cho unit tests với fake server và khả năng thay thế libssh2 nếu có vấn đề tương thích.

5. Concurrency & threading

Tauri event loop luôn đáp ứng UI, không chạy blocking libssh2 trên UI thread.

Nếu dùng ssh2 (Rust binding tới libssh2, sync), mỗi session chạy trong dedicated blocking worker/thread với bounded worker budget, message queue điều khiển, cancellation token; **không chia sẻ session handle tùy tiện giữa nhiều thread**.

Terminal output stream có bounded buffer; backpressure hoặc drop behavior chỉ áp dụng diagnostics event, **không bỏ dữ liệu terminal tùy ý**. Với output quá lớn cần flow control/đọc có giới hạn, đo memory.

SFTP transfers có concurrency mặc định 2 và cap cấu hình; mỗi transfer có cancellation token, state persist độc lập.

UI render throttled theo animation frame; terminal nhận chunk hợp lý, không gửi mỗi byte qua Tauri event.

6. Session state machine

```
stateDiagram-v2
 [*] --> Idle
 Idle --> Resolving: connect
 Resolving --> Connecting
 Connecting --> VerifyingHost
 VerifyingHost --> Authenticating: trusted/approved
 VerifyingHost --> Failed: mismatch/rejected
 Authenticating --> Connected: authenticated
 Authenticating --> Failed: error
 Connected --> Interrupted: network lost
 Interrupted --> Resolving: user retry
 Connected --> Closing: disconnect
 Failed --> Resolving: user retry
 Failed --> Closed: close
 Closing --> Closed
 Closed --> [*]
```

Mọi state transition tạo typed event session.statusChanged; frontend không giả định thành công từ lệnh connect trả về việc request đã được nhận.

7. Data and lifecycle

app_state snapshot metadata, host/group/settings trong SQLite; secret value không được cache vào Redux store hoặc localStorage.

On connect, Rust SecretStore lấy secret theo ref; giữ trong memory ngắn nhất có thể. Đóng session xóa reference buffers/handle best-effort; zeroization có giới hạn khi FFI/library giữ bản sao.

Host key được xác minh **trước** auth. Known-hosts file/in-app trust DB cần theo hostname + port + key algorithm và fingerprint; đổi key tạo security event.

Local files path cần allowlist user-selected scope; không có lệnh arbitrary filesystem từ untrusted UI payload.

App exit: attempt graceful close, cancel transfer, persist known-safe states, không để SSH/SFTP worker/process orphan.

8. Sequence: connect SSH

```
sequenceDiagram
 actor User
 participant UI as React UI
 participant Core as Rust Core
 participant DB as SQLite
 participant SSH as SSH Adapter
 participant Vault as Keychain
 participant Host as SSH Host
 User->>UI: Connect host
 UI->>Core: connect_host(hostId)
 Core->>DB: get host profile
 Core->>SSH: resolve/connect/handshake
```

```
SSH->>Host: exchange SSH host key
SSH-->>Core: host key fingerprint
Core->>DB: check known host
alt unknown
 Core-->>UI: trustRequest(fingerprint)
 User->>UI: approve or reject
 UI->>Core: resolveTrust(requestId, decision)
else mismatch
 Core-->>UI: HOST_KEY_MISMATCH
end
Core->>Vault: retrieve auth secret (if needed)
Core->>SSH: authenticate + create shell/PTY
SSH-->>Core: session channel ready
Core-->>UI: session.statusChanged CONNECTED
```

9. Sequence: SFTP atomic upload

```
sequenceDiagram
 actor User
 participant UI
 participant Core
 participant SFTP
 participant Remote
 User->>UI: Upload local file
 UI->>Core: enqueue_transfer(src,dest,conflictPolicy)
 Core->>SFTP: create remote temporary file
 loop chunks
  SFTP->>Remote: write bytes
  SFTP-->>UI: transfer.progress
 end
 SFTP->>Remote: close + verify metadata/checksum if supported
 SFTP->>Remote: rename temporary to target
 SFTP-->>Core: completed or partial failure
 Core-->>UI: transfer.statusChanged
```

Nếu server không hỗ trợ POSIX atomic rename hoặc checksum, app phải chuyển sang fallback có thông báo; không khẳng định tính atomic khi chưa được đảm bảo.

10. Performance budgets — proposed, must benchmark

Cold start target p90 <=3s target reference hardware; inventory render <=200ms với 1,000 hosts từ local DB.

Session count initial cap: 10 concurrent SSH shells; SFTP transfer concurrency 2; cap configuration và smoke tests.

RAM budget target TBD từ measurement; không hứa “nhẹ hơn Electron” nếu chưa benchmark.

App closes idle sessions only with explicit setting and clear warning; no invisible auto-kill.

11. Cross-platform strategy

P0 macOS Keychain provider. Windows: Credential Manager; Linux: Secret Service/libsecret (future adapters).

macOS RDP external launcher là P1; platform-specific availability và supported CLI/options phải kiểm thử.

UI components và domain model portable; protocol feature flags riêng theo OS.

No shared native RDP binary shipping cho tới khi signing, Hardened Runtime, codecs và third-party licenses được audit.

12. Observability and failure recovery

Log có structured fields: timestamp, action_id, host_id hashed/local id, module, duration_ms, error_code; không log password, terminal content, file payload, raw private key, query string chứa token. Audit log cho thay đổi host/credential metadata; log rotation. Crash recovery khôi phục tab placeholders thay vì tự reconnect.

D06 — Domain Model, ERD & SQLite Schema

1. Bounded contexts

Inventory: Workspaces, Groups, Hosts, Tags, SSH/RDP ConnectionProfiles.

Identity: CredentialReferences, TrustedHostKeys (không chứa secret values).

Runtime: Sessions ephemeral + recent session metadata, Transfers durable metadata.

Preferences: AppSettings, LayoutSnapshots, AuditEvents.

2. Domain invariants

Host ID là UUID v7 hoặc UUID v4 (chốt khi implement), không sử dụng hostname làm khóa.

Một Host có thể có nhiều ConnectionProfile (ví dụ SSH 22 và RDP 3389), mỗi profile có auth reference tùy chọn.

CredentialReference mapping vào Keychain external; DB có thể mất Keychain item, UI phải báo CREDENTIAL_UNAVAILABLE và cho rebind.

TrustedHostKey scope hostname:port + algorithm + fingerprint (SHA256); fingerprint không phải bí mật nhưng luôn cần bảo vệ integrity.

Recent sessions chỉ lưu metadata, không lưu keystrokes, transcript, passwords.

Transfer source/destination path có thể chứa tên nhạy cảm; retention ngắn và có setting tắt lịch sử.

3. ERD

```
erDiagram
 WORKSPACE ||--o{ HOST : groups
 WORKSPACE ||--o{ HOST_GROUP : contains
 HOST_GROUP ||--o{ HOST : classifies
 HOST ||--o{ CONNECTION_PROFILE : has
 HOST ||--o{ HOST_TAG : tagged
 TAG ||--o{ HOST_TAG : references
 CONNECTION_PROFILE }o--o| CREDENTIAL_REF : uses
 CONNECTION_PROFILE ||--o{ RECENT_SESSION : opens
 CONNECTION_PROFILE ||--o{ TRANSFER_JOB : transfers
 HOST ||--o{ AUDIT_EVENT : emits
```

Implementation note: dữ liệu host_group_id nullable, mặc định một workspace có nhiều groups. Sơ đồ là model khái niệm; constraints chi tiết xem schema.

4. Tables

workspaces — **Primary Key:** id; **Main columns:** name, color, created_at; **Security note:** Không secrets

host_groups — **Primary Key:** id; **Main columns:** workspace_id, name, sort_order; **Security note:** FK workspace

hosts — **Primary Key:** id; **Main columns:** workspace_id, group_id, display_name, address, environment; **Security note:** Address có thể nhạy cảm; local only

connection_profiles — **Primary Key:** id; **Main columns:** host_id, protocol, port, username, credential_ref, options_json; **Security note:** Options JSON allowlist, không secrets

credential_refs — **Primary Key:** id; **Main columns:** label, kind, keychain_item_id, created_at; **Security note:** Keychain item_id chỉ là locator, không secret

tags — **Primary Key:** id; **Main columns:** name; **Security note:** Unique normalized

host_tags — **Primary Key:** composite; **Main columns:** host_id, tag_id; **Security note:** Join table

trusted_host_keys — **Primary Key:** composite; **Main columns:** endpoint, key_algorithm, fingerprint_sha256, first_seen; **Security note:** Integrity-critical

recent_sessions — **Primary Key:** id; **Main columns:** connection_profile_id, started_at, ended_at, status, error_code; **Security note:** No transcript

transfer_jobs — **Primary Key:** id; **Main columns:** connection_profile_id, local_path, remote_path, bytes_total, state; **Security note:** Paths sensitive; short retention

audit_events — **Primary Key:** id; **Main columns:** action, entity_id, outcome, error_code, occurred_at; **Security note:** Redacted, no raw payload

app_settings — **Primary Key:** key; **Main columns:** json_value; **Security note:** No secrets; schema validation

5. SQL baseline

File specs/schema.sql bao gồm các CREATE TABLE, FK, CHECK, UNIQUE, INDEX; được dùng làm baseline, không coi là migration production. Database có PRAGMA foreign_keys=ON trên mỗi connection; dùng WAL và busy_timeout theo QA. Schema version qua PRAGMA user_version, future migrations có transactional backups.

6. Retention & cleanup

Audit metadata lưu tối đa 7 ngày và 10 MB mặc định, user có thể vô hiệu hóa hoặc xóa.

Transfer history lưu 30 ngày mặc định, cho phép clear all; không tự xóa file trên máy chỉ vì xóa record.

Recent session 90 ngày; no terminal recording.

Trusted-host entries giữ tới khi user revoke; key mismatch không tự động cập nhật.

File export luôn metadata-only, không copy local paths/tunnel bind targets nếu chứa bí mật không cần thiết; field inclusion có explicit policy.

7. Index and migrations

hosts(workspace_id, environment), hosts(display_name COLLATE NOCASE), connection_profiles(host_id, protocol), recent_sessions(started_at DESC).

SQLite FTS5 optional cho fast search sau benchmark; inventory 1k chưa bắt buộc.

Trước migration: sao lưu metadata database vào file có permission giới hạn, verify free disk; nếu migration fail restore/rollback và show recovery steps. Không tự đồng bộ vào cloud.

8. Sample JSON export contract


```
{
 "schema_version": 1,
 "generated_at": "2026-10-26T13:00:00Z",
 "workspaces": [
  {"id": "c6a81b85-2f53-4d5e-9cd3-d6e0aa6b060c", "name": "Demo"}
 ],
 "hosts": [
  {"id": "cf468f8a-aad7-48a1-91a8-2ab262f66ce3", "workspace_id": "c6a81b85-2f53-4d5e-9cd3-d6e0aa6b060c",
"display_name": "Dev Ubuntu", "address": "dev.example.net", "environment": "development"}
 ],
 "connection_profiles": [
```

```
  {"host_id": "cf468f8a-aad7-48a1-91a8-2ab262f66ce3", "protocol": "ssh", "port": 22, "username": "developer",
"auth_required": true}
 ],
 "secrets_included": false
}
```


Đây là ví dụ minh họa. **Import/export schema cuối cùng cần đối chiếu với TypeScript type declarations**, validate dữ liệu ngoài và transaction trước khi áp dụng.

D07 — SSH, SFTP, RDP, Tunnels & Session Lifecycle

1. SSH design

Selection candidate: Rust ssh2 crate (bindings tới libssh2). Lợi thế: SSH client + SFTP + ssh-agent support, mature protocol stack. Hạn chế: API blocking và phụ thuộc native/OpenSSL; cần dedicated workers, supply-chain scan, platform compilation matrix. Quyết định cuối cùng sau Spike SP-01; nghiên cứu russh như alternative nếu case khác biệt chứng minh.

Handshake và trust

Validate host profile (address, port, username, auth kind).

DNS resolve + TCP connect với timeout/cancel.

SSH key exchange, lấy public host key/algorithm và tính SHA256 fingerprint.

Kiểm tra known-hosts theo hostname+port; matched cho phép auth, unknown phải được người dùng chấp nhận, mismatch block hard.

Auth via password or key/ssh-agent; SSH agent identities phải được người dùng chọn nếu có nhiều lựa chọn.

Open shell + request PTY (rows/cols, terminal type) và stream output.

Shutdown/timeout/cancel close channel/socket; state event nhất quán.

Do not: auto-accept unknown host, fallback sang thuật toán yếu không cảnh báo, log auth material, đặt password vào command-line args, retry failed authentication vô hạn.

Terminal

UI sử dụng xterm.js để render byte stream thành terminal emulator; Rust giữ session/channel và chuyển bytes qua bounded event bridge. Input Unicode/IME, paste lớn, OSC sequences, terminal hyperlink và clipboard cần kiểm tra XSS/escape injection, bao gồm OSC 52 clipboard, click URL, shell escape. Không tự render terminal output thành HTML bằng innerHTML. On resize gửi SSH window change, không chỉ CSS.

Authentication priority

Private key file path qua user selection; secret passphrase ở Keychain nếu user chọn save.

SSH Agent identity path tránh sao chép key secret; cần xác nhận identity nào được dùng.

Password authentication sử dụng Keychain; interactive keyboard-interactive auth chỉ hỗ trợ khi spike/test đảm bảo.

Keychain locked/prompt rejected => CREDENTIAL_UNAVAILABLE hoặc CREDENTIAL_ACCESS_DENIED, không ngầm retry.

2. SFTP design

Supported P0: list, stat, mkdir, rename, delete single selection with confirm, upload/download, conflict policy, progress, cancel. Batch multi-file transfer chỉ ở P0 nếu queue/state đã ổn định; otherwise milestone sau.

Path policy: OS filesystem file path và remote POSIX-style path là hai kiểu khác nhau; không nối bằng string không kiểm tra. Remote names có thể chứa newline/control codes; sanitize khi display/alert, giữ nguyên byte semantics

trong protocol. Symlink traversal phải bảo vệ thao tác destructive. Không cố giả định mọi server đều hỗ trợ symlink, posix-rename, checksum, fsync.

Transfer algorithm

TRANSFER_CREATED -> VALIDATING -> RUNNING -> VERIFYING -> COMPLETED / FAILED / CANCELLED.

Upload: nếu có thể, sử dụng temp path bất ngờ trong cùng directory, ghi chunks, close, kiểm tra bytes, rename vào đích với conflict policy; nếu server không đảm bảo atomic rename thì cảnh báo và không cam kết rollback.

Download: ghi vào .part dưới user-selected local folder, flush/sync đủ mức, kiểm tra size, rename sau khi complete. Nếu disk full, giữ metadata FAILED và cleanup file .part có kiểm soát.

Retry không mặc định overwrite target. Resume optional không thuộc P0 vì SFTP server behavior khác nhau.

Concurrency 2 default, không giới hạn memory theo số file; streaming chunks và bounded queue.

3. SSH tunneling (P1)

Chỉ **local port forward** lúc đầu: bind 127.0.0.1, forward TCP tới remote host/port qua SSH. Người dùng chọn local port, kiểm tra đã bị dùng, allow cancel/close, hiện endpoint rõ. 0.0.0.0 không cho default; nếu support sau này phải có elevated warning, không lộ tunnel ngoài máy ngoài ý muốn. Dynamic/remote forwarding sang P2 có threat review riêng.

4. RDP external launcher (P1)

Goal: cho phép người dùng từ host profile mở Windows desktop trong client RDP đã cài, không phải embed RDP trong Tauri. RDP protocol được delegated cho external client nên app không đảm bảo kết nối thành công, clipboard, audio, multi-monitor hay session persistence.

Capability detection: tìm approved RDP clients/URL schemes đã xác minh trên macOS matrix.

User chọn client ở Settings; app hướng dẫn mở nếu chưa cài.

Avoid passing password via command-line arguments, URL hoặc generated config. Username/domain chỉ đi nếu backend/client support an toàn; fallback copy endpoint không secrets.

RDP profile files (.rdp) chỉ được generate với các trường non-secret và có vòng đời temp file/cleanup + permission restrictive.

Chỉ hiển thị Launched, không hiển thị Connected nếu không có reliable protocol callback.

RDP embedded (P2 feasibility gate)

Lựa chọn FreeRDP Apache-2.0 cho native engine. Cần spike giải quyết: macOS native window/surface embedding, Tauri/WebView interoperability, NLA/CredSSP, TLS/certificate pinning, HiDPI, keyboard maps, clipboard, audio/USB policies, reconnect, multi-monitor, performance, sandbox/signing/notarization. Không đặt FreeRDP framebuffer raw làm DOM video path nếu chưa chứng minh latency, security và accessibility. Nếu spike không đạt, duy trì external launcher thay vì đánh đổi an toàn.

5. Session registry

Session ID là UUID, không persist channel handle. Registry giữ map sessionId -> {profileId, protocol, state, workerHandle, openedAt, lastHeartbeat}. Một host được mở nhiều session; ngắt kết nối một session không tự đóng các session khác trừ khi có dependency tunnel explicit.

connect() trả operationId/sessionId và state ban đầu. Event session.statusChanged phản ánh handshake/auth. disconnect() idempotent; unknown session id trả 404-style semantic code mà không làm crash app. UI phải unsubscribe listeners khi unmount; Rust phải giải phóng channel khi frontend tab bị đóng.

6. Security-relevant failure scenarios

DNS fails — **Handling:** DNS_RESOLUTION_FAILED, show resolver/diagnostic suggestion

Host key changed — **Handling:** Hard stop, show old/new fingerprints và out-of-band instructions

Auth rejects — **Handling:** Stop auth retry, distinguish password/key agent

Keychain deny — **Handling:** Do not fallback insecure storage; ask reauthorize

Network drops during upload — **Handling:** Mark transfer INTERRUPTED, no fake completed result

RDP client unavailable — **Handling:** Show install/select client, copy endpoint fallback

App quit with file transfer — **Handling:** Confirm cancellation and perform best-effort cleanup

7. Compatibility matrix (planned)

Ubuntu 22.04/24.04 OpenSSH — **SSH:** P0; **SFTP:** P0; **RDP:** —

Debian current stable OpenSSH — **SSH:** P0; **SFTP:** P0; **RDP:** —

Windows OpenSSH Server — **SSH:** P1 candidate; **SFTP:** P1 candidate; **RDP:** —

Windows Server 2019/2022/2025 — **SSH:** —; **SFTP:** —; **RDP:** P1 external / P2 embedded

macOS OpenSSH test host — **SSH:** P0 CI where feasible; **SFTP:** P0 CI; **RDP:** —

Những dòng là **test targets**, không phải cam kết đã kiểm thử. Cần cập nhật OS/server version theo support lifecycle tại thời điểm phát hành.

D08 — Tauri IPC Commands, Events and Domain Contracts

1. Principles

Frontend chỉ dùng typed invoke wrappers, không gọi shell/native APIs trực tiếp. Rust commands kiểm tra input bằng strict schema (serde, explicit enum) và policy (user action, host scope, permission) trước khi I/O. Tauri capability permissions hạn chế window/webview exposure, nhưng vẫn phải validate authorization và state tại implementation command.

Bất kỳ command nào có side effect phải trả operationId hoặc entity ID để correlate events.

Errors có shape ổn định: code, message, retryable, operationId, details redacted.

Streaming bytes qua event envelopes, chunk size bounded, sequence number để phát hiện missing/out-of-order; khi UI render không kịp thì có flow-control policy.

sessionId khác profileId; never accept a host address from UI streaming event as final authority (lookup DB by profile ID).

2. Command inventory

workspace.list — **Input:** none; **Output:** Workspace[]; **Auth/policy:** main window

workspace.upsert — **Input:** WorkspaceInput; **Output:** Workspace; **Auth/policy:** validation

host.list — **Input:** workspaceId?, query?; **Output:** HostSummary[]; **Auth/policy:** read-only metadata

host.upsert — **Input:** HostInput; **Output:** Host; **Auth/policy:** validate endpoint

host.delete — **Input:** hostId, confirmToken; **Output:** ok; **Auth/policy:** explicit confirm, unlink refs

credentials.store — **Input:** type, value, label; **Output:** credentialRef; **Auth/policy:** secure IPC, no logging

credentials.remove — **Input:** credentialRef, confirmToken; **Output:** ok; **Auth/policy:** check shared consumers

ssh.connect — **Input:** profileId; **Output:** sessionId + operationId; **Auth/policy:** trust+auth flow

ssh.trust_decision — **Input:** requestId, allow, persist; **Output:** ok; **Auth/policy:** active pending challenge

ssh.write — **Input:** sessionId, bytes; **Output:** acceptedBytes; **Auth/policy:** connected session

ssh.resize — **Input:** sessionId, cols, rows; **Output:** ok; **Auth/policy:** cols/rows bounds

ssh.disconnect — **Input:** sessionId; **Output:** ok; **Auth/policy:** idempotent

sftp.list — **Input:** sessionId, path; **Output:** RemoteFile[]; **Auth/policy:** secure session

sftp.enqueue_transfer — **Input:** profileId, direction, paths, policy; **Output:** jobId; **Auth/policy:** path capabilities

sftp.cancel_transfer — **Input:** jobId; **Output:** ok; **Auth/policy:** in-flight only

sftp.mutate — **Input:** sessionId, action, path, confirmToken; **Output:** ok; **Auth/policy:** destructive confirmation

rdp.launch_external — **Input:** profileId; **Output:** launched/error; **Auth/policy:** P1, no secret in args

data.export — **Input:** selection, targetToken; **Output:** operationId; **Auth/policy:** metadata-only

data.import_preview — **Input:** sourceToken; **Output:** ImportPreview; **Auth/policy:** no DB mutations

data.import_commit — **Input:** previewId, decisions; **Output:** result; **Auth/policy:** transactional

Implementation note: Tauri Rust #[tauri::command] names may use snake_case under the hood. The dotted names above are a **public logical API catalog**, not copy/paste code for registration. Map them consistently in ipc/command-map.ts and Rust command handlers; do not assume default Tauri dispatch understands dotted namespaces.

3. Events

session.statusChanged — **Payload:** sessionId, status, error?; **Frequency / lifetime:** transition only

ssh.hostTrustRequired — **Payload:** requestId, endpoint, fingerprint, keyAlgorithm; **Frequency / lifetime:** on first seen/change policy

ssh.output — **Payload:** sessionId, seq, base64Chunk/bytes; **Frequency / lifetime:** batched; no persistence

ssh.windowResized — **Payload:** sessionId, dimensions; **Frequency / lifetime:** optional ack

transfer.progress — **Payload:** jobId, transferredBytes, totalBytes?; **Frequency / lifetime:** throttle 100–250ms

transfer.statusChanged — **Payload:** jobId, state, error?; **Frequency / lifetime:** transition only

notification — **Payload:** severity, code, operationId; **Frequency / lifetime:** important events

ssh.output content phải được xterm.js decode đúng byte encoding. Không đưa raw terminal bytes vào analytics/logging. Frontend unsubscribe khi session gone; event bus có backpressure và bounded queue.

4. Example IPC request/response

```
// logical API types; actual invoke command binding is explicit
interface ConnectHostRequest { profileId: string }
interface ConnectHostResponse { sessionId: string; operationId: string; status: 'resolving' | 'connecting' }

interface AppError {
  code: 'HOST_KEY_MISMATCH' | 'AUTH_FAILED' | 'TCP_TIMEOUT' | 'INVALID_INPUT' | 'UNEXPECTED_INTERNAL' |
string;
  message: string;
  retryable: boolean;
  operationId?: string;
  details?: Record<string, string | number | boolean>;
}
```

5. Host trust authorization

A trust challenge là object ephemeral có requestId, profileId, hostname, port, key fingerprint, expiresAt, nonce. UI chỉ gửi decision + requestId; Rust so khớp challenge còn sống, cùng phiên SSH và endpoint đang chờ. Không chấp nhận fingerprint do UI tự gửi lên để rewrite trust DB. Mismatch không có path auto-override; rotation là workflow riêng sau manual verification.

6. Idempotence, validation, concurrency

disconnect/cancel_transfer idempotent.

upsert có optimistic concurrency (updated_at/version) tránh ghi đè khi nhiều window trong tương lai.

File mutation buộc xác nhận theo path, action, sessionId, expiration ngắn và single-use token.

Không gửi plaintext credentials qua global frontend stores/loggers; khi nhập credential form, minimize lifetime; không lưu browser autofill/localStorage.

Rate-limit connect attempts per profile; cancellation token propagate tới DNS/TCP/SSH worker best-effort.

7. API versioning

contract_version thuộc app package; không tồn tại remote server API ở P0. Schema breaking change đi cùng app migration và E2E tests. Deprecated IPC chỉ tồn tại tối đa một major release nếu có plugin/external clients sau này.

8. Spec artifacts

specs/ipc.types.ts đưa ra types baseline để implement app/features, src-tauri/commands; cần import enums từ một nguồn và generate docs/test snapshots nếu sau này thay đổi.

D09 — Security Architecture & Threat Model

1. Security goals

Confidentiality: mật khẩu, passphrase và key material không rò trong DB, export, log, crash report, argv.

Integrity: host identity không bị thay đổi âm thầm; file transfers không ghi sai đích hoặc bị coi thành công giả.

Availability: remote output lớn, queue dài hoặc network failure không làm treo app hay gây retry storm.

User agency: thao tác nguy hiểm phải rõ host, path, environment và xác nhận.

2. Trust boundaries và STRIDE

WebView → Rust IPC — **Threat:** Tampered input, privilege escalation; **Mitigation:** Capabilities theo window, typed validation, command policy, confirm tokens; **Test:** SEC-T01

Rust → Keychain — **Threat:** Secret leakage/replay; **Mitigation:** OS keychain, scoped item attributes, minimal access, zero secret logging; **Test:** SEC-T02

SSH → remote host — **Threat:** MITM host key substitution; **Mitigation:** strict known host verification trước auth, mismatch hard block; **Test:** SEC-T03

Remote SFTP file names — **Threat:** Path traversal/control chars; **Mitigation:** canonicalization where reliable, safe display, explicit target path, no shell interp; **Test:** SEC-T04

File transfer — **Threat:** Partial overwrite/corruption; **Mitigation:** temp file, verify supported attributes, safe rename/fallback warning; **Test:** SEC-T05

External RDP — **Threat:** Credentials exposed via argv/temp files; **Mitigation:** no password args; sanitized config and cleanup; clipboard beyond app control; **Test:** SEC-T06

Local database — **Threat:** Host inventory / operational metadata disclosure; **Mitigation:** OS file permissions, lock, optional encrypted DB future; no plaintext secrets; **Test:** SEC-T07

App updates — **Threat:** Supply-chain compromise; **Mitigation:** signed releases, notarization, SBOM, pinned dependencies, controlled update channel; **Test:** SEC-T08

Terminal output — **Threat:** Escape-sequence/XSS/clipboard attack; **Mitigation:** xterm parsing; OSC/links allowlist and opt-in clipboard; **Test:** SEC-T09

SSH tunnels — **Threat:** Unintended listening on public interface; **Mitigation:** bind loopback default, port validation, explicit user visibility; **Test:** SEC-T10

3. Keychain and credential management

Use Apple Security Keychain Services to store small secrets. credential_refs.keychain_item_id is only locator/identifier; **not password**.

Credential types: password, key passphrase, maybe RDP password stored for later integration but **do not hand off into external app by argv**.

Private SSH key: keep file in user-controlled protected path / ssh-agent; do not copy private key bytes into SQLite. The app must honor filesystem permission and never autoscan whole disk for keys.

Avoid storing secrets in frontend persistent state; React forms hold short-lived values, clear on completion/unmount best-effort.

Add credential usage summary and unlink/revoke. Orphan secret cleanup requires confirmation and shared reference count.

Failed unlock must not fall back to plaintext store.

4. SSH host verification

TOFU with approval: unknown host shows fingerprint/algorithm and suggestion of **out-of-band verification**. Unknown key is not automatically trustworthy.

Mismatch: block; user must verify with sysadmin and explicitly rotate existing trust in Known Hosts management. Rotation generates audit event.

Warn for weak/unsupported host key algorithm; never silently downgrade policy to make connection pass.

known_hosts scope hostname/port/algorithm/fingerprint; if reusing OS file, honor format and permissions. Avoid colliding writes with other SSH clients; in-app trust DB may be simpler but distinct to users.

5. Secure-by-default UX

Prominent PRODUCTION badge in terminal and SFTP headers; destructive ops show host + absolute remote path.

Never execute custom snippets automatically at connect or on import.

Prevent copy-to-clipboard of secrets by default and display warning if user requests.

Open external links only for allowlisted schemes (https, mailto if approved). SSH terminal clickable URLs require explicit confirmation for non-HTTPS schemes.

6. IPC and local attack surface

Tauri capabilities bound to main window; no remote origin command access. IPC handlers must validate entities against local DB instead of trusting arbitrary URLs/paths. Disallow shell execution with interpolated strings. If spawning external tools, use typed argv arrays with fixed executable path and fields; keep secrets off argv/environment and temporary files when possible.

Caution: Tauri command registration/permissions can vary; need audit registered commands and capability config under each release. Capability config is not a substitute for policy checks in Rust.

7. SFTP safety

Normalize display separately from remote path identity; files named .., symlinks, control characters need explicit tests.

All file writes require target-dir selected by user. Local filesystem selected through OS file picker; for sandboxed distribution persist security-scoped bookmark if needed.

Upload temp/rename protected from race with another remote process: re-stat before replace, prevent silent overwrite; UX must disclose potential TOCTOU limitation.

Download destination under user-selected directory and .part strategy; no automatic remote script execution.

8. Privacy and telemetry

No account and no built-in analytics/telemetry by default.

Diagnostic report generated locally and requires user action to share; redact hostname/IP/path by user selection.

Crash reporter optional, off by default, must scrub secrets and terminal contents; user can view report before send if implemented.

Logs metadata-only with default short retention and clear-all support.

9. Distribution hardening

Build hardened runtime; sign Developer ID; notarize and staple direct-download .dmg/.app where supported.

Audit bundled library licenses and native dependencies; scan CVEs; pin lockfiles and verify checksums.

Security update channel must verify signature, support rollback to trusted build where feasible, and never silently install unverified executable.

Mac App Store version (sandbox rules) is **not** an initial commitment.

10. Security acceptance gates

SQLite strings/fixture scan contains no test passwords, passphrases or raw private key blocks.

Host-key mismatch test cannot invoke authentication even with UI tampering.

External RDP launch never includes secret in argv, generated profile or logs.

Malformed remote filenames cannot escape intended UI actions/execute code.

Terminal content with OSC 52 cannot silently read/write clipboard contrary to policy.

Disconnect/quit clears sensitive handles best-effort, file transfers have explicit terminal status.

Signed/notarized build passes Gatekeeper on a clean Mac without disabling security.

11. Residual risks

If host OS compromised, Keychain/session data can be exposed to sufficiently privileged attacker; local-first is not a guarantee against endpoint compromise.

Keychain data can be queried under macOS access-control prompts/policies; do not promise perfect in-memory zeroization across FFI.

RDP external client has its own certificate/security policy beyond MRW control.

Native dependency CVEs/security patch turnaround require maintained release process.

D10 — Test Strategy, Test Matrix and Quality Gates

1. Testing strategy

Risk-based testing: first focus host trust, secrets, file writes, session lifecycle; then reliability, performance, accessibility. Units test pure state machines & validation; integration test actual SSH/SFTP service with ephemeral containers; E2E test packaged macOS app on clean machines. RDP external test manual+automation where possible; RDP embedded requires separate validation program P2.

2. Test environments

macOS arm64 current supported — **Mục tiêu:** Main dev + signed DMG smoke

macOS x86_64 supported — **Mục tiêu:** Intel compatibility, package smoke

macOS oldest supported version — **Mục tiêu:** Keychain, Tauri WebView, binary compatibility

Ubuntu OpenSSH test container — **Mục tiêu:** SSH auth/key/PTY & SFTP lifecycle

Host with modified SSH host key — **Mục tiêu:** MITM/mismatch rejection

Network proxy simulator — **Mục tiêu:** DNS fail, TCP drop, RTT/jitter/loss

SFTP permission fixture — **Mục tiêu:** Read-only folders, symlinks, collision, disk full

Windows Server RDP test host — **Mục tiêu:** External launcher profile (P1)

Version targets are candidates, not verified compatibility claims. Maintain pinned runner/container image versions in CI.

3. Unit tests — major groups

HostInput: empty, invalid IP/FQDN, 0/65536 port, Unicode host label, oversized strings, environment enum.

TrustDecision: unknown -> pending, mismatch -> fail, stale nonce -> fail, user reject -> closed.

SessionReducer: all legal/illegal transitions, reconnect, duplicate close.

Transfer: cancel at each state, rename fallback, collision and unexpected file size.

CredentialRefs: deleting shared creds, orphan detection, DB-rebind logic.

ExportSanitizer: ensures metadata-only whitelist; fuzz secret-like fields; roundtrip version.

EventBridge: sequencing, listener unregister, bounded buffering, oversize output.

4. Integration tests — acceptance table

TC-001 — **Scenario:** Add/edit/delete host; **Expected:** DB correct; constraints applied

TC-002 — **Scenario:** Query host inventory 1k/10k; **Expected:** Search result correct, target budget logged

TC-003 — **Scenario:** Save credential → inspect SQLite/export; **Expected:** Secret absent, Keychain item exists

TC-004 — **Scenario:** Unknown SSH host key; **Expected:** Requires user decision before auth

TC-005 — **Scenario:** SSH host key mismatch; **Expected:** Hard block, no auth attempt

TC-006 — **Scenario:** SSH password and public-key login; **Expected:** Correct result, error codes distinct

TC-007 — **Scenario:** Parallel shells and PTY resize; **Expected:** No hang/leak, resize passes

TC-008 — **Scenario:** FTP-like SFTP listing incl. Unicode/symlink; **Expected:** Safe display/path handling

TC-009 — **Scenario:** Upload/download 10MB/1GB incl cancel; **Expected:** Verified bytes, no false success

TC-010 — **Scenario:** Overwrite with collision and interrupted transfer; **Expected:** Explicit policy, source preserved

TC-011 — **Scenario:** Relaunch workspace; **Expected:** Layout restored, no auto-login by default

TC-012 — **Scenario:** Export/import metadata; **Expected:** No secrets, duplicate review, transaction

TC-013 — **Scenario:** UI keyboard-only/VoiceOver; **Expected:** Keyboard flows success

TC-014 — **Scenario:** RDP launcher no client installed (P1); **Expected:** Useful fallback; no password in argv

TC-015 — **Scenario:** Local SSH port forwarding (P1); **Expected:** Loopback only; teardown cleans listener

TC-016 — **Scenario:** App quit with running upload; **Expected:** Prompt, cancel cleanup, no leaked workers

TC-017 — **Scenario:** Host DB migration interruption; **Expected:** Rollback/recovery without silent data loss

TC-018 — **Scenario:** Error redaction test; **Expected:** No credentials/terminal transcript logged

TC-019 — **Scenario:** URL/terminal escape injection; **Expected:** Disallowed schemes/OSC clipboard blocked

TC-020 — **Scenario:** Notarized release on clean Mac; **Expected:** Gatekeeper opens without bypass

TC-021 — **Scenario:** DNS/TCP/SSH connection diagnostics (P1); **Expected:** Errors localized to layer; no secrets in report

TC-022 — **Scenario:** Command snippets require confirmation (P1); **Expected:** No commands run at connect/import automatically

TC-023 — **Scenario:** Shared credential unlink and delete; **Expected:** Shared secret not deleted while referenced; confirm effects

TC-024 — **Scenario:** Reconnect storm throttling; **Expected:** Exponential backoff/cap/cancel, no command replay

5. E2E user journeys

E2E-A: onboarding → add Ubuntu host → verify SHA256 → SSH → SFTP download → close session.

E2E-B: production host → upload file conflict → cancel → verify original file unchanged.

E2E-C: offline launch → browse host list → connect timeout → troubleshooting hint → reconnection manual.

E2E-D (P1): add Windows host → select external RDP client → launch safely → verify process argv sanitized.

E2E-E: keyboard-only navigation, reduce motion, VoiceOver labels, light/dark theme and scaling.

6. Performance experiments

Cold start: 30 runs on clean cache/warm cache separately; p50/p90, RAM baseline.

Terminal stress: 1/5/10 concurrent SSH shells; output sustained 1–5 MB/min per session; CPU/RAM, missing bytes/latency.

Transfer: files 0 bytes, 4KB, 100MB, 1GB; direct LAN, 100ms RTT, 2% loss; throughput/cancel reliability.

Inventory: 1k, 10k hosts seed; search/scroll memory and frame latency.

App soak: 8h with connection open/close cycles and transfers; file descriptor leak check.

No claim of meeting a budget before results are recorded. Reference hardware and network constraints must be included with every public benchmark.

7. Security/fuzz testing

Fuzz hostname, config JSON, IPC payload, terminal escape sequences, remote filename, import manifest.

Simulated compromised host with key rotation; verify block and audit.

OS Keychain denied/locked, corrupted DB, missing native OpenSSL dependency.

Secret search in DB/log/export/argv/crash; use sentinel canary credentials, never real passwords.

Verify update package signature and negative tampered package test.

8. CI pipeline test gates

PR: format, TS lint/typecheck, Rust fmt/clippy, unit, integration where available, license scan, lockfile verification, build artifact.

Nightly: macOS app E2E, SSH/SFTP matrix, soak lite, dependency advisory scan.

Release candidate: full e2e, notarization, clean-machine smoke, performance report, threat model review, release notes and SBOM.

9. Definition of Done / pass criteria

Every P0 FR has at least 1 automated test or documented manual acceptance (security-critical MUST automated).

No open P0/P1 blocker bug involving data loss, auth bypass, host key mismatch, secret exposure, crash during transfers.

Tests for false-positive completion and cancel behavior passed.

App opens on two CPU architectures, signed/notarized artifact verified.

User documentation and recovery instructions published.

D11 — Build, Release, Distribution & Operational Runbook

1. Environments

development: developer signing ad hoc only; debug data entirely synthetic.

integration: CI artifacts with ephemeral SSH/SFTP test containers; no production secrets.

release-candidate: Developer ID-signed and notarized binary installed on clean test Macs.

stable: public signed DMG/ZIP, checksums, release manifest and notes.

2. Proposed repo CI/CD

```
flowchart LR
 A[Pull Request] --> B[TS typecheck/lint/tests]
 A --> C[Rust fmt/clippy/unit tests]
 B --> D[Integration SSH/SFTP]
 C --> D
 D --> E[Build unsigned preview]
 E --> F{Tag/release approval?}
 F -->|Yes| G[macOS signed build]
 G --> H[Apple notarization]
 H --> I[Staple + Gatekeeper test]
 I --> J[SBOM + SHA256 + Release]
```

Example local commands — illustrative, validate against scaffold

```
pnpm install --frozen-lockfile
pnpm lint
pnpm typecheck
pnpm test
cargo fmt --all -- --check
cargo clippy --workspace --all-targets -- -D warnings
cargo test --workspace
pnpm tauri build
```

The scripts lint, typecheck, test need to be defined in package.json, and Rust workspace/Cargo invocation may require running in src-tauri. Do not run commands on production hosts; here they build the local app.

3. Signing and notarization

Register Apple Developer ID Application signing cert; store credentials in secure CI secrets, not repository.

Hardened Runtime on executable+sidecars; no broad entitlements by default.

codesign --verify --deep --strict --verbose=2 /path/MacRemoteWorkspace.app (verification starting point).

Submit through Apple notary service using Xcode or xcrun notarytool submit ... --wait with secret profile, then staple using xcrun stapler staple ... where applicable.

Verify on clean Mac with Gatekeeper enabled (spctl, actual Finder launch, app network functions). For sidecar/bundles, inspect code signatures individually.

macOS App Store is not promised: sandbox and RDP/SSH integration behavior may require a separate design/entitlements strategy.

4. Dependency compliance

Track Rust crates, JS packages, native libssh2/OpenSSL, xterm.js, RDP external integrations. Produce SPDX/CycloneDX SBOM; keep license attributions. FreeRDP Apache-2.0 is candidate for P2 only; audit transitive native codecs and optional components before embedding. Run cargo audit/npm advisory scan and establish remediation SLA by severity.

5. Privacy default and support diagnostics

No telemetry sent automatically; update check opt-in or first-run disclosure if enabled.

Export diagnostics redacts credentials and terminal content, allows user review before saving/sharing.

Debug log: local-only, default 7-day rotation, configurable disable; mask host data in public bug reports.

Settings Clear History and Delete All Local Data require confirmation; differentiate from Keychain revoke.

6. User upgrade and rollback

Before schema migration backup DB metadata; versioned migrations, recovery on failure.

Updates cryptographically verified/signed; no executable loaded from untrusted server without verification.

Downgrade may be incompatible with newer schema; document supported downgrade path; keep backup original metadata for recovery.

Restore should not overwrite Keychain unexpectedly.

7. Support/runbook errors

Cannot connect — **Diagnosis:** DNS/TCP timeout/refused; **User action:** Verify host/port/VPN/firewall

Host key mismatch — **Diagnosis:** Changed SSH server key or MITM; **User action:** Stop, validate host fingerprint out of band

Password not accessible — **Diagnosis:** Keychain denied/locked; **User action:** Unlock/rebind; no plaintext fallback

SFTP permission denied — **Diagnosis:** OS permission / remote ACL; **User action:** Check ownership and selected remote path

External RDP not found — **Diagnosis:** Client missing / URL integration changed; **User action:** Select supported client/copy endpoint

App blocked by Gatekeeper — **Diagnosis:** Missing/invalid signing/notarization; **User action:** Download official signed release, do not disable Gatekeeper

Transfer incomplete — **Diagnosis:** Network/disk/permission; **User action:** Inspect job error and destination .part state before retry

8. Release checklist

Gate checklist sống ở checklists/release-gates.md. Stable release requires CHANGELOG, known limitations, license inventory, privacy disclosure, binary checksums, documented supported macOS versions, security contact and reproducible build steps where possible.

D12 — Roadmap, Epics, User Stories & Work Breakdown

1. Timeline baseline

Bảng dưới là **ước lượng cho 1 developer có kinh nghiệm làm việc tập trung**, chưa tính lịch cá nhân và các vấn đề native/RDP chưa xác minh. Các milestone có thể thực hiện nối tiếp hoặc song song nếu có đội ngũ.

M0 Discovery/spikes — **Weeks (estimate):** 1–2; **Deliverable:** Confirm SSH2, Keychain, Tauri signing, file permissions; **Gate:** Spike reports pass

M1 Foundation — **Weeks (estimate):** 2–3; **Deliverable:** Host/groups CRUD, SQLite migrations, IPC, design system; **Gate:** FR-001–004 baseline

M2 SSH terminal — **Weeks (estimate):** 2–3; **Deliverable:** Trust, auth, PTY, xterm, reconnect; **Gate:** TC-004–007 pass

M3 SFTP & transfer — **Weeks (estimate):** 2–3; **Deliverable:** Dual-pane, queue, atomic/fallback policy; **Gate:** TC-008–010 pass

M4 Harden & beta — **Weeks (estimate):** 1–2; **Deliverable:** Import/export, accessibility, signing, E2E; **Gate:** Security and release gates

M5 V1.0 — **Weeks (estimate):** +3–5; **Deliverable:** RDP external, tunnels, diagnostics; **Gate:** P1 tests pass

M6 V2.0 RDP embedded — **Weeks (estimate):** Research-led; **Deliverable:** Native RDP prototype and compatibility matrix; **Gate:** Explicit go/no-go

Total MVP rough order: 8–12 weeks if spikes pass and scope discipline maintained; risk-adjusted longer for part-time or new Rust proficiency.

2. Epics with user stories

EPIC-01 Foundation & Inventory

US-001 (P0, 3 pts): As user, I can create/edit host profile with environment and protocol; acceptance FR-001.

US-002 (P0, 3 pts): I can create workspace/group/tag and move host; FR-002.

US-003 (P0, 2 pts): I can search host by name/tag/environment, keyboard-driven; FR-003.

US-004 (P0, 3 pts): I can import/export metadata safely; FR-014 (after security review).

EPIC-02 Credentials & Security

US-005 (P0, 5 pts): Save/rebind credentials in Keychain by reference; FR-004, FR-025.

US-006 (P0, 5 pts): Unknown host key is shown for out-of-band verify, mismatch blocks; FR-006.

US-007 (P0, 3 pts): App ships with redacted structured logs, safe external URL policy; FR-013, FR-026.

EPIC-03 SSH Terminal

US-008 (P0, 8 pts): Connect via SSH password/key/agent, categorized errors; FR-005.

US-009 (P0, 5 pts): PTY terminal tabs, resize, UTF-8; FR-007.

US-010 (P0, 5 pts): Reconnect/manual retry and cleanup; FR-008, FR-027, FR-028.

EPIC-04 SFTP File Manager

US-011 (P0, 5 pts): Browse remote SFTP paths safely; FR-009.

US-012 (P0, 8 pts): Upload/download queue with cancel/progress and safe temporary strategy; FR-010.

US-013 (P0, 5 pts): Confirm overwrite/delete/rename, show remote target; FR-011.

EPIC-05 UX & Quality

US-014 (P0, 5 pts): Workspace restore with sessions unconnected by default; FR-012.

US-015 (P0, 5 pts): Keyboard and accessibility; FR-015.

US-016 (P0, 5 pts): Signed/notarized beta with traceability and release checklist; NFR-011.

EPIC-06 V1.0 additions

US-017 (P1, 5 pts): RDP external launcher with no secrets in args; FR-016.

US-018 (P1, 5 pts): Loopback-only SSH local tunnel; FR-017.

US-019 (P1, 3 pts): DNS/TCP/SSH diagnostics; FR-018.

US-020 (P1, 3 pts): User-approved snippets + command palette; FR-019/020.

EPIC-07 V2 research

US-021 (P2, spike): FreeRDP native window embedding, keyboard/clipboard/HiDPI benchmark; FR-021.

US-022 (P2): SSH jump host support after host trust chain review; FR-022.

US-023 (P2): Readonly server metrics; FR-023.

Points là relative estimates để chia việc, không dùng tự động quy đổi thành số giờ chính xác.

3. Backlog dependency

```
flowchart TD
 A[SP-01 SSH library spike] --> B[EPIC-03 SSH]
 C[SP-02 Keychain/signing] --> D[EPIC-02 Security]
 E[EPIC-01 Inventory] --> B
 E --> F[EPIC-04 SFTP]
 B --> F
 B --> G[EPIC-06 Tunnel]
 H[SP-03 RDP launcher] --> I[EPIC-06 RDP]
 J[SP-04 FreeRDP embed] --> K[EPIC-07 Embedded RDP]
```

4. Suggested first two sprints (2 weeks each)

Sprint 1: repo bootstrap, ADR acceptance, UI shell, workspace/host tables + CRUD, Keychain proof, signer/hardened runtime prototype. Deliverable: user can add hosts and see inventory.

Sprint 2: known-host verification, SSH password/public key integration with test server, terminal channel + PTY, error taxonomy. Deliverable: user can safely connect to SSH server and disconnect.

5. Go/no-go milestones

Gate G1: SSH2/libssh2 works on signed/notarized arm64 + x86_64 artifact with host trust and key auth. If fails, evaluate russh/other adapter; do not hard-wire vendor into UI.

Gate G2: Keychain refs survive app restart, deny permission gracefully, no secrets in DB/logs.

Gate G3: SFTP cancellation/retry cannot silently corrupt/overwrite pre-existing target.

Gate G4: P1 RDP launcher safely launches installed client without secrets in argv.

Gate G5: P2 FreeRDP window interaction is validated before setting any V2.0 release date.

6. Sample GitHub issue template

```
### Story
US-008: SSH password/key/agent authentication
```

Requirements
FR-005, FR-006, SEC-xxx
Scope
- Connect through SSH Transport trait
- Verify host key before authentication
- Emit typed errors
Acceptance
- TC-004, TC-005, TC-006 pass
- No secrets logged
Evidence
- Unit/integration logs redacted; screenshot of trust dialog
Definition of Done
- Code review, tests, docs updated, no unresolved security issue

D13 — Architecture Decision Records, Risks and Spikes

1. Accepted/proposed ADRs

ADR-001 — **Status:** Proposed; **Decision:** macOS-first app via React+Tauri+Rust; **Rationale:** Reuse TypeScript skills, Rust transport, macOS packaging; **Revisit trigger:** UX/perf spike rejects

ADR-002 — **Status:** Proposed; **Decision:** Local-first no cloud/backend; **Rationale:** Simpler privacy and offline inventory; **Revisit trigger:** Team sync product demand validated

ADR-003 — **Status:** Proposed; **Decision:** Secrets in macOS Keychain, metadata SQLite; **Rationale:** Separation of secret/data and OS integration; **Revisit trigger:** Security audit issues

ADR-004 — **Status:** Proposed; **Decision:** libssh2 / Rust ssh2 for initial SSH/SFTP prototype; **Rationale:** Mature client functions; sync worker isolation; **Revisit trigger:** Compatibility/threading failure

ADR-005 — **Status:** Proposed; **Decision:** RDP through external client in V1, FreeRDP embedded V2; **Rationale:** Deliver safe MVP without native rendering risk; **Revisit trigger:** Embedded spike passes early

ADR-006 — **Status:** Proposed; **Decision:** No terminal recording/default telemetry; **Rationale:** Privacy by default, reduce risk; **Revisit trigger:** Explicit opt-in feature demand

ADR-007 — **Status:** Proposed; **Decision:** Separate UI typed IPC and Rust policy engine; **Rationale:** Testability, least privilege; **Revisit trigger:** None

ADR-008 — **Status:** Proposed; **Decision:** Direct-download Developer ID notarized first; **Rationale:** Avoid App Store sandbox promise; **Revisit trigger:** App Store distribution request

ADR-009 — **Status:** Proposed; **Decision:** AGPLv3 or Apache-2.0 must be selected before public code publication; **Rationale:** OSS strategy impacts inbound contributions/commercial use; **Revisit trigger:** Maintainer decision

ADR-009 note: Propose **Apache-2.0** as default if broad adoption, integration and low friction are primary. If copyleft enforcement is deliberate project objective, seek legal review before choosing AGPLv3; cannot treat both as equivalent. No license file should be generated with an undecided license.

2. Technical risk register

R-01 — **Risk:** libssh2 build/hardened runtime/macOS x86_64 issue; **Likelihood:** Medium; **Impact:** High; **Mitigation:** SP-01 compile+package smoke early; **Owner/Exit:** Transport lead; G1

R-02 — **Risk:** SSH host key verification bypass via UI path; **Likelihood:** Low–Med; **Impact:** Critical; **Mitigation:** Rust policy and adversarial tests; **Owner/Exit:** Security; SEC-T03

R-03 — **Risk:** Keychain errors/locked access disrupt login; **Likelihood:** Medium; **Impact:** High; **Mitigation:** SP-02 and recovery UX; **Owner/Exit:** Platform; G2

R-04 — **Risk:** Interrupted SFTP overwrites remote target; **Likelihood:** Medium; **Impact:** Critical; **Mitigation:** temp/verify/rename; crash tests; **Owner/Exit:** SFTP; G3

R-05 — **Risk:** External RDP client integration varies by OS/version; **Likelihood:** High; **Impact:** Medium; **Mitigation:** SP-03, fallback copy endpoint; **Owner/Exit:** Platform; G4

R-06 — **Risk:** FreeRDP embed performance/input issues; **Likelihood:** High; **Impact:** High; **Mitigation:** Separate SP-04, P2 only; **Owner/Exit:** Platform; G5

R-07 — **Risk:** Unsupported macOS oldest target; **Likelihood:** Medium; **Impact:** Medium; **Mitigation:** CI clean-machine test matrix; **Owner/Exit:** Release

R-08 — **Risk:** Network dead sessions leak workers; **Likelihood:** Medium; **Impact:** High; **Mitigation:** cancellation, bounded queues, soak tests; **Owner/Exit:** Runtime

R-09 — **Risk:** Dependency vulnerability/unsafe plugin; **Likelihood:** Medium; **Impact:** High; **Mitigation:** audit, lockfile, SBOM, plugin after P2; **Owner/Exit:** Security

R-10 — **Risk:** Feature parity chase vs Termix; **Likelihood:** High; **Impact:** Product high; **Mitigation:** focus context-first workflows; **Owner/Exit:** Product

R-11 — **Risk:** Security-scoped local path inaccessible; **Likelihood:** Medium; **Impact:** Medium; **Mitigation:** sandbox strategy, OS picker/bookmarks; **Owner/Exit:** UX/Platform

R-12 — **Risk:** Secret leaked through diagnostics/clipboard; **Likelihood:** Medium; **Impact:** Critical; **Mitigation:** structured redaction, test sentinels; **Owner/Exit:** Security

3. Feasibility spike protocols

SP-01 — SSH/SFTP transport (2–4 developer-days estimate)

Build minimal Rust libssh2 POC: password, SSH agent, key file+passphrase, host key SHA256 verification, 10 shells, sftp 100 MB, cancellation. Run arm64+x86_64 binary, notarization feasibility. Measure build size, CPU/RAM, behavior on 100ms RTT. Decision PASS / ALTERNATIVE / BLOCKED with reproducible commands.

SP-02 — Keychain and permissions (1–2 days)

Create/select/delete Keychain item with access control, locked/unavailable behavior; integrate UserSelected file picker; sign/notarize sample. Verify DB/logs contain no secret. Compare sandbox/non-sandbox distribution assumptions.

SP-03 — RDP external launcher (1–3 days)

Survey installed supported RDP clients on macOS; verify launch method/API/sanitized profile, process argv, cleanup temp file, fallback copy endpoint. Explicitly distinguish launched and connected.

SP-04 — FreeRDP embedded (5–10+ days, P2)

Prototype sidecar/native engine with Swift/AppKit host surface or other credible integration approach. Validate security (TLS/NLA), keyboard mapping, HiDPI, resizing, clipboard, multiple displays, memory/latency, signing/notarization. No version promise until this passes.

4. Decision logs template

```
# ADR-NNN: Short title
Status: Proposed | Accepted | Rejected | Superseded
Date:
Context:
Decision:
Options considered:
Security/privacy effects:
Consequences:
```

Validation evidence:
Review date:

5. Assumptions to validate with real users

IT users prefer client-local credential storage to synced vault; validate across 5–10 user interviews.

Context-based production warning reduces mistakes rather than alert fatigue; test task completion in usability study.

SFTP dual-pane handles 80% routine transfers; measure actual task patterns.

External RDP launcher is acceptable in V1; beta feedback to validate before spending embedded RDP effort.

macOS-first adoption enough to justify native focus; research Windows demand with GitHub issues/polls.

D14 — Open Source Governance, License and Community Plan

1. Licensing recommendation

For a general-purpose desktop utility, **Apache-2.0** is the recommended option to review before public repository launch: permissive contributions/integrations, explicit patent grant, widespread ecosystem compatibility. This is a project recommendation, **not legal advice**. Decision must be finalized and an official LICENSE/NOTICE added before accepting contributions or distributing third-party bundled binaries.

Alternative: MIT is simpler but lacks the same explicit patent formulation.

AGPLv3 is an option for deliberate network copyleft objective but may complicate enterprise adoption; assess legal and dependency compatibility first.

FreeRDP reports Apache License; check exact versions and bundled native components before distributing embedded RDP engine.

Third-party acknowledgments required for xterm.js, Rust crates, binaries, fonts/assets.

2. Repository governance

README.md: value proposition, screenshots, support, install links, security notes.

CONTRIBUTING.md: setup requirements, coding conventions, tests, issue templates, DCO/CLA decision.

CODE_OF_CONDUCT.md: contributor behavior.

SECURITY.md: private vulnerability reporting, supported versions, disclosure window.

PRIVACY.md: no data collection by default, local storage, diagnostics, how to delete data.

CHANGELOG.md: Keep a Changelog; SemVer for public API if plugin API introduced.

3. Contribution process

Label issues: good-first-issue, help-wanted, bug, security, protocol:ssh, protocol:sftp, ux, macos.

Small PR focused on module + tests + FR reference + screenshots for UI.

Security-sensitive PR (Keychain, host trust, IPC, transfer overwrite) requires second reviewer before merge.

No production credentials/screenshots showing real IP/domains in issues; provide synthetic fixtures.

Community translation after UI text keys stable; Vietnamese and English at first release.

4. Project structure and product ethos

Offline first, no account, no mandatory telemetry.

Monetization if introduced should not create surprise restrictions on previously open core capabilities; explain roadmap and license changes transparently.

Avoid copying third-party UI assets/screenshots into product without permissions.

Developer may contribute to Termix/FreeRDP upstream where appropriate rather than duplicating maintenance work.

5. Initial public launch checklist

License chosen, author rights confirmed, CONTRIBUTING/SECURITY/privacy docs.

Screenshots sanitized, onboarding docs, install methods, release artifacts signed/notarized.

Small reproducible integration test environment available.

Source code secrets scanner clean; fixtures synthetic only.

Roadmap honest about RDP launcher vs embedded RDP.

6. Suggested community roadmap

0.1.0-alpha: inventory, host trust and basic SSH.

0.2.0-alpha: SFTP queue, safe transfer, keyboard/accessibility pass.

0.5.0-beta: signed/notarized beta, import/export, docs and privacy review.

1.0.0: external RDP, local SSH tunnel and stable core, after all gates pass.

2.0.0: embedded RDP only if feasibility and security matrix pass; otherwise 1.x continues.

These are semantic targets, not fixed shipping dates.

D15 — Research and Technical References

Sources consulted as of 26/10/2026. Official documentation links should be rechecked before implementation because software versions and API signatures change.

Official project/documentation sources

Tauri v2 — Capabilities: permissions granted to windows/webviews, least privilege, command exposure implications.X

Tauri Security Architecture: WebView–Rust IPC trust boundary and policy ownership.X

FreeRDP GitHub: RDP protocol library/clients; project describes Apache licensing.X

Rust ssh2 crate: Rust bindings for libssh2, client SSH interfaces.X

Rust ssh2 KnownHosts: check_port, known-hosts trust and fingerprint comparison primitives.X

Apple Keychain Services: securely store small chunks of secret data.X

Apple Notarizing macOS software: Developer ID, hardened runtime, signing, notarization/stapling.X

Apple Accessing files from macOS App Sandbox: security-scoped bookmarks/user-selected files for sandboxed apps.X

xterm.js GitHub: terminal emulator and addon ecosystem.X

xterm.js Addons: rendering and fit behavior.X

Termix GitHub: existing SSH, SFTP, RDP and server management competitor; project describes Apache-2.0.X

1Remote GitHub: Windows-focused multi-protocol remote access manager and launcher.X

Notes on what was/was not verified

Verified from official references: Tauri capability model exists; Apple Keychain/Notarization are supported services; ssh2 crate uses libssh2; FreeRDP is a RDP engine released under Apache; Termix already provides broad remote access features.

Not validated by executable spike: choice of Rust SSH crate under signing/hardened runtime; safe external RDP launcher compatibility with specific macOS RDP applications; FreeRDP embedding in Tauri; measured macOS memory/performance; macOS minimum supported version; cross-platform roadmap feasibility. These must remain feasibility gates (D13).

Product research disclaimer

No user interview survey or statistically representative market-size analysis was performed for this document. Differentiation and adoption hypotheses must be tested during beta. Do not treat requirements design as market validation.

D16 — Implementation Blueprint and Repository Layout

1. Monorepo proposed tree

```
mac-remote-workspace/
├── apps/
│   └── desktop/
│       ├── src/
│       │   ├── app/                # bootstrap, routes, shell
│       │   ├── features/
│       │   │   ├── inventory/
│       │   │   ├── workspaces/
│       │   │   ├── credentials/
│       │   │   ├── terminal/
│       │   │   ├── sftp/
│       │   │   ├── transfers/
│       │   │   ├── rdp-launcher/     # P1
│       │   │   └── settings/
│       │   ├── shared/ui/
│       │   ├── shared/validation/
│       │   └── shared/ipc/
│       └── src-tauri/
│           ├── capabilities/
│           ├── migrations/
│           ├── src/
│           │   ├── commands/
│           │   ├── domain/
│           │   ├── repository/
│           │   ├── services/
│           │   ├── adapters/ssh/
│           │   ├── adapters/sftp/
│           │   ├── adapters/keychain/
│           │   ├── adapters/rdp/     # P1
│           │   ├── runtime/
│           │   └── security/
│           └── tauri.conf.json
├── packages/
```

```
│   ├── ipc-contract/              # TypeScript contract + schemas
│   └── design-tokens/
├── docs/                          # this design set, ADRs
├── tests/
│   ├── fixtures/
│   ├── integration/ssh-sftp/
│   ├── e2e/macos/
│   └── security/
├── .github/workflows/
└── scripts/
```

2. Implementation conventions

Frontend: React 19 + TypeScript strict. Data-fetching and IPC commands in hooks/services, view components presentation-focused, no secrets in global state/devtools. Prefer React Compiler compatibility, avoid unnecessary manual memoization; component tests + accessibility.

Rust: module isolation, traits for SecretStore/SSH/SFTP/HostRepository, typed errors, no panic on untrusted input, careful cancellation/Drop. Avoid generic shell command executor in app core.

IPC: packages/ipc-contract defines request/response/event TS interfaces; Rust serde types need contract parity tests. All invoke calls via typed facade with explicit command map, no direct invocation scattered across UI components.

Migrations: SQL versioned migrations + transactional tests, before/after fixture snapshots; DB foreign keys on per connection.

Error semantics: stable AppErrorCode enum and mapping to localized user messages; error wrapping in Rust preserves internal cause for redacted logs without leaking data.

3. Suggested technology decisions

Desktop shell — **Candidate:** Tauri 2; **Why / caveat:** macOS packaging, Rust backend; IPC policy review necessary

UI — **Candidate:** React 19, TS, Vite; **Why / caveat:** Developer productivity, maintainable components

Terminal emulator — **Candidate:** xterm.js; **Why / caveat:** PTY browser rendering; OSC/security tests necessary

Local DB — **Candidate:** SQLite, sqlx/rusqlite candidate; **Why / caveat:** Mature local storage; choose based on Rust async/blocking model

SSH/SFTP — **Candidate:** ssh2/libssh2 initially; **Why / caveat:** SSH agent, known_hosts, SFTP; worker thread discipline

Secrets — **Candidate:** macOS Security.framework Keychain adapter; **Why / caveat:** OS-level protection, access-control prompts

RDP P1 — **Candidate:** Approved external RDP client; **Why / caveat:** Don't store secrets in process args

RDP P2 — **Candidate:** FreeRDP prototype; **Why / caveat:** Native rendering/signing/input risks, spike-gated

Testing — **Candidate:** Rust tests, Vitest, Playwright/macOS native smoke; **Why / caveat:** Multiple levels; Playwright alone cannot validate RDP/Keychain

Versions intentionally not pinned in a planning document. Pin in lockfile after compatibility spike; do not assume latest version will build on minimum macOS target.

4. Setup prerequisites

Xcode command line tools, Rust toolchain (rustup), Node supported LTS, pnpm, Tauri build prerequisites, optional Homebrew for libssh2/OpenSSL build testing. Provide .tool-versions/Volta/engines and reproducible bootstrap script after selecting exact versions.

5. Incremental first-implementation slices

Slice A: UI shell + Host CRUD + SQLite + tests. Demonstrate no SSH yet.

Slice B: Keychain wrapper + HostKeyPolicy + SSH handshake with local OpenSSH integration test.

Slice C: PTY streaming + resize + cancellation + 10 concurrent sessions.

Slice D: SFTP remote listing + transfer engine + collision tests.

Slice E: import/export, UX accessibility, signed release and Gatekeeper smoke.

6. GitHub agent-ready task contract

A coding agent may implement a task only with: requirement IDs, path ownership, test/acceptance expectations, security constraints, out-of-scope and review checklist. Avoid prompts such as “implement the full app” and avoid hidden auto-execution privileges.

Example:

Implement US-006 / FR-006 in Rust app core.
Scope: host key verification BEFORE credential retrieval/authentication.
Constraints: unknown requires UI trust challenge; mismatch is hard stop;
never auto-trust, never log secrets; create tests TC-004 and TC-005.
Do not modify RDP, transfer or telemetry modules. Return exact files changed,
commands executed, test results, unresolved risks and screenshots if UX changed.

7. Implementation readiness checklist

☐ ADR-001–009 reviewed by maintainer.

☐ SP-01–03 POC reports attached.

☐ Requirement IDs assigned to tracked GitHub issues.

☐ Test infrastructure creates real SSH/SFTP test server.

☐ CI contains secret scanner, package audit and code sign plan.

☐ Project license/third-party notices approved before publishing.